UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 0 slot(s). Supported theory: 24 slots. Placeholders: 0. Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 15 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 0 computed, 24 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) differences between morals and laws as described in the lecture on ethics and computer security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Morals are described as traditions of belief concerning right and wrong conduct within a society.	"Morals are traditions of belief about right and wrong conduct"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.67	supported (ste gate)
2	Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six (6) professional conduct requirements that the ACM code of ethics places on a computing professional, as presented in the lecture on ethics and computer security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The professional must aim for high quality in the processes and products of their professional work.	"Strive to achieve high quality in both the processes and products of professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.75	supported (ste gate)
2	The professional must keep up high standards of competence, conduct and ethical practice.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.78	supported (ste gate)
3	The professional must be aware of, and respect, the existing rules that apply to professional work.	"Know and respect existing rules pertaining to professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.62	supported (ste gate)
4	The professional must give and accept	"Accept and provide appropriate professional review."	071 - Ethics and Computer	071 - Ethics and Computer	0.60	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	suitable professional review.		Security, slide 12	Security::s12::1		
5	The professional must only carry out work in areas where they are competent.	"Perform work only in areas of competence."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.40 LOW	supported
6	The professional must design and implement systems that are both robustly and usably secure.	"Design and implement systems that are robustly and usably secure."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.67	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 12

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

A company is deploying a network-based intrusion detection system (NIDS) across its campus network. List TWO (2) typical locations where NIDS sensors should be placed.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Sensors should be positioned on the network segment just inside the firewall.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.38 LOW	supported
2	Sensors should be positioned on the demilitarized zone (DMZ).	"On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.17 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 7

A2b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain three preventive network security mechanisms that an organization can deploy to protect its network, and for each mechanism describe how it controls or secures network traffic.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A firewall controls incoming and outgoing network traffic according to predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.80	supported (ste gate)
2	A proxy server acts as a firewall and web filter, provides shared network connections, and caches data to speed up common requests, improving data security and network performance.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.83	supported (ste gate)
3	Network segmentation creates boundaries between network segments whose computing assets share a common function,	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.80	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	risk, or role within the organization.					
4	A remote access VPN provides individual hosts or clients with remote and secure access to an organization's network.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.90	supported (ste gate)
5	Zero Trust Network Access (ZTNA) ensures a user only has the access and permission required to fulfill the role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.61	supported (ste gate)
6	Intrusion detection/prevention systems detect or prevent network security attacks such as brute force attacks, Denial-of-Service attacks, and exploits of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the Chinese Wall model as a formal security model, stating the specific concern it was designed to address and how its access decisions differ from static policies.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Chinese Wall policy was proposed by Brewer and Nash to address conflicts of interest, and it is an access control confidentiality policy rather than an integrity policy.	"Brewer and Nash (1989) proposed a policy called the Chinese Wall Policy that addresses such conflicts of interest."	024 - Formal Security Model, slide 21	024 - Formal Security Model::s21::1	0.57	supported (ste gate)
2	Access decisions under the Chinese Wall depend on the subject's history of past accesses, so permissions change dynamically rather than being fixed in advance.	"The access rights that any subject enjoys depends on the history of past accesses"	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.31 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 24

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six points about the access control matrix, access control lists and capabilities as access control structures, covering what each structure represents and the stated advantages or disadvantages of these structures.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment

© Hak Cipta Universiti Teknologi MARA

1	The access control matrix is presented as a basic control structure for implementing access policies.	"ACM is a basic control structure."	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.43 LOW	supported
2	The matrix is credited with clarity of definition and being easy to verify.	"Advantages: clarity of definition easy to verify"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.50	supported (ste gate)
3	The matrix suffers from poor scalability and poor handling of changes.	"poor handling of changes"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.50	supported (ste gate)
4	An ACL is described as an object-centred description of access rights.	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.83	supported (ste gate)
5	ACLs give easy access to object access rights and are relatively easy to manage using abstractions.	"easy access to object access rights relative easiness of management using abstractions"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.88	supported (ste gate)
6	ACLs are disadvantaged by a poor overview of access rights per subject and by difficulty of revocation and sharing.	"poor overview of access rights per subject difficulty of revocation difficulty of sharing"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.73	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 8

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) facts about the chain of trust in Trusted Computing, including how measurements are stored and where the chain begins.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Measurements taken during the chain of trust are recorded in Platform Configuration Registers (PCRs) located on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.50	supported (ste gate)
2	The chain of trust originates at the hardware TPM and then proceeds through software components such as RTM, TPM Software Stack, BIOS and kernel.	"The chain starts with the hardware TPM, then software: RTM,TPM Software Stack, BIOS, kernel"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.64	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 8

A4b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the roles of the two primary system components of the Next Generation Secure Computing Base

© Hak Cipta Universiti Teknologi MARA

(NGSCB), and describe how the Nexus interacts with trusted software and the TPM.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Nexus is a special kernel that forms the core of the trusted operating environment.	"Special kernel (core of the trusted operating)"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.62	supported (ste gate)
2	The Nexus isolates normal-mode processes from trusted-mode processes by placing them differently in memory.	"Isolate the process of normal mode and trusted mode differently in memory"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.67	supported (ste gate)
3	The Nexus is a security kernel that is authenticated on boot and authenticates trusted programs.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.57	supported (ste gate)
4	The Nexus provides the application interface to the TPM and does not trust the OS.	"Application interface to TPM"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.38 LOW	partly supporte
5	The Nexus Computing Agent (NCA) is a trusted software component that runs in trusted mode and communicates with the Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.56	supported (ste gate)
6	NCA specifications are open-source, allowing developers to create their own agents to run on the trusted platform.	"Developers can make their own agents to run on the trusted platform"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.55	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) ways in which a documented code of ethics guides the ethical conduct of computing professionals, as described in the lecture on ethics and computer security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	It makes the accepted standards of behaviour clearer to understand.	"Adds clarity to the understanding of acceptable standards of behavior."	071 - Ethics and Computer Security, slide 8	071 - Ethics and Computer Security::s08::1	0.50	supported (ste gate)
2	It communicates shared guidelines that everyone is expected to follow.	"Communicates common guidelines for everyone to follow."	071 - Ethics and Computer Security, slide 8	071 - Ethics and Computer Security::s08::1	0.67	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 8

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Compare the responsibilities that the ACM code of ethics places on a computing professional with respect to privacy and confidentiality, and explain how a documented code of ethics supports an organisation in enforcing acceptable professional behaviour.

© Hak Cipta Universiti Teknologi MARA

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The professional must protect personal information by respecting privacy as a stated obligation.	"Respect privacy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.25 LOW	supported
2	The professional must safeguard information entrusted to them by honouring confidentiality.	"Honor confidentiality."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.12 LOW	supported
3	The professional must act honestly and be worthy of trust when handling stakeholder data.	"Be honest and trustworthy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.10 LOW	supported
4	The professional must consider all people affected by computing as stakeholders and contribute to their well-being.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.60	supported (ste gate)
5	A code of ethics is a written record of the behaviours a professional group deems acceptable.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.33 LOW	supported
6	The code is established by the professional body itself, giving the organisation authority to define what counts as appropriate conduct.	"Defined by the group."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.09 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 6

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the two stages of the biometric authentication process and state what happens during each stage.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The identification stage involves acquiring the biometric sample, creating the master characteristics, and storing those master characteristics.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.33 LOW	supported
2	The authentication stage involves further acquisition(s), comparison against the stored data, and a decision.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). A bank plans to replace password logins at its branch counters with biometric authentication. Explain six points the bank must consider regarding biometric mechanisms and technologies, covering the definition of a biometric, its categories, and specific technologies with their limitations.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A biometric is defined as a physiological or behavioural characteristic of a human being that can distinguish one person from another and can theoretically be used for identification or verification of identity.	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.92	supported (ste gate)
2	Biometric applications are categorized into two sectors, namely psychological (physiological) and behavioural.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.62	supported (ste gate)
3	The psychological category includes iris, fingerprints, hand, retinal and face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.78	supported (ste gate)
4	The behavioural category includes voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
5	Iris scanning reads the unique pattern of the iris, requires no touch, and overcomes retinal scanner issues, though contact lenses may be an issue.	"Scans unique pattern of iris"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1	0.27 LOW	partly supporte
6	Fingerprint biometrics suffer disadvantages such as racial issues, dirt, grime and wounds, finger placement problems, and the need for liveness detection because they can be spoofed.	"Can be spoofed - liveness important!"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.15 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) characteristics of a Trojan horse as a type of malware.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojans typically disguise themselves as useful or benign programs.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.17 LOW	supported
2	Trojans steal private	"begin to steal private data, delete files, log keystrokes or provide an	051 - Software Security, slide	051 - Software Security::s12::1	0.25 LOW	supported

© Hak Cipta Universiti Teknologi MARA

	information or otherwise damage the host system.	opening for further malware to get installed"	12			

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six (6) techniques by which malware propagates itself or infects host programs and systems, as described in the lecture material.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A virus can spread by infecting the boot sector of a disk.	"A program spread via boot sector infection"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.57	supported (ste gate)
2	A worm can propagate across a network by exploiting a remote execution feature of a service such as sendmail.	"Used a debugging feature of sendmail (remote execution)"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.27 LOW	supported
3	An executable COM file can be infected by appending the virus body to the program and redirecting the entry point to the virus.	"Append a virus body to a program"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.33 LOW	partly supporte
4	An executable EXE file can be infected by overwriting the program header so that the entry point switches to the virus.	"Over write a program header to switch the entry point to a virus"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.50	supported (ste gate)
5	A rootkit is typically installed after a vulnerability has been found and detected, allowing the attacker to keep control of the infected machine.	"They are usually installed after a vulnerability has been found and detected so that the infected computer continues to be under the control of the malware author."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.57	supported (ste gate)
6	Spyware can redirect the user's browser to unwanted sites as part of its spying behaviour.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 7; 051 - Software Security, slide 9

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how the classes of threats described in the lecture can impact the confidentiality, integrity and availability of a system's assets.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Disclosure threats such as snooping, sniffing and wiretapping give unauthorized access to	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide	011 - Introduction to Computer Security::s10::1	0.36 LOW	partly supporte

	information, which harms confidentiality.		10			
2	Deception involves acceptance of false data, and integrity services are the countermeasure against it.	"Deception - acceptance of false data"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.44 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the Samy worm as a case study of a cross-site scripting (XSS) attack, covering how the malicious script was injected, how it spread to other users, and the outcome of the incident.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by writing to the document body.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.67	supported (ste gate)
2	The script retrieved the victim's list of friends (heros) by issuing a GET request on a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.30 LOW	supported
3	The worm added Samy as a friend by performing an XML-HTTP request on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
4	Any user visiting an infected profile had their own profile and friends list infected, enabling self-propagation.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.46 LOW	supported
5	The incident ultimately infected approximately one million MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.29 LOW	supported
6	The root cause is that any web application returning unfiltered user input is a potential XSS vulnerability.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the goals of access control and the role of a reference monitor in realizing access control policies.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control aims to grant, limit, prevent and revoke access.	"Goals of access control: Granting access Limiting access Preventing access Revoking access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	0.86	supported (ste gate)
2	Reference monitors are	"Reference monitors are	023 - Access	023 - Access	0.54	supported (ste

© Hak Cipta Universiti Teknologi MARA

	the instruments used to realize access control policies and can be deployed at all levels of the system hierarchy.	instruments for realization of access control policies."	Control and Authorization, slide 18	Control and Authorization::s18::1		gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 4

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the formal security models covered in the lecture, focusing on the Bell-La Padula, Biba and Chinese Wall models. In your answer, explain the concern each model addresses and the specific access rules that the Chinese Wall model imposes on subjects.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Bell-La Padula model is presented as a formal model concerned with access control only.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.75	supported (ste gate)
2	The Biba model is distinguished from BLP by adding integrity verification.	"Biba model: additional integrity verification"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.57	supported (ste gate)
3	The Chinese Wall model is described as identifying conflicts of interest.	"Chinese Wall model: identification of conflicts of interest"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	1.00	supported (ste gate)
4	The Chinese Wall simple security rule permits a subject to access an object only when that object is either in the same company dataset as objects the subject has already accessed (i.e., within the Wall) or belongs to a completely different conflict of interest class.	"is in the same company datasets as the objects already accessed by s, that is, "within the Wall," or belongs to an entirely different conflict of interest class."	024 - Formal Security Model, slide 25	024 - Formal Security Model::s25::1	0.52	supported (ste gate)
5	Under the Chinese Wall *-property, a write is allowed only if the simple security rule permits it and no readable object lies in a different company dataset while holding unsanitized information.	"Write access is only permitted if: access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information."	024 - Formal Security Model, slide 26	024 - Formal Security Model::s26::1	0.55	supported (ste gate)
6	The Chinese Wall policy is designed to address the specific concern of conflicts of interest for a consultant or contractor, and its access decisions depend on the history of past accesses.	"Unlike previous policies, Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor."	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.67	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26; 024 - Formal Security Model, slide 27; 024 - Formal Security Model, slide 5

© Hak Cipta Universiti Teknologi MARA

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two ways in which an intrusion detection system supports the detection and defence of a system against attacks.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	An IDS can detect malicious activity occurring in computer systems.	"Detects malicious activity in computer systems"	062 - Intrusion Detection System, slide 2	062 - Intrusion Detection System::s02::1	0.62	supported (ste gate)
2	An IDS can identify and stop an attack that is currently in progress.	"Identifies and stops attacks in progress"	062 - Intrusion Detection System, slide 2	062 - Intrusion Detection System::s02::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 2

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six (6) points from the lecture that characterise threat classes and the countermeasures used against them, covering how threats, attacks and vulnerabilities are distinguished, how malware is described, and how protective mechanisms are classified.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A threat is defined as an object, person or other entity that represents a constant danger to an asset.	"Threat: object, person, or other entity representing a constant danger to an asset"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.90	supported (ste gate)
2	An attack is a deliberate act that exploits a vulnerability.	"Attack: a deliberate act that exploits vulnerability"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	1.00	supported (ste gate)
3	Protection of assets covers prevention, detection and response techniques.	"Protection of assets encompasses prevention, detection and response techniques"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.86	supported (ste gate)
4	A threat is characterised as a potential violation of security, whereas an attack is the actual violation.	"Attacks: The actual violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.50	supported (ste gate)
5	Malware research includes Cohen's formal definition of a virus and a mathematical description of how viruses propagate.	"Mathematical description of virus propagation"	051 - Software Security, slide 6	051 - Software Security::s06::1	0.40 LOW	partly supporte
6	Sandboxing is a countermeasure that provides a safe, protected and isolated environment for running or opening suspected insecure programs or files.	"A safe, protected and isolated environment in computer system to run or open suspected insecure programs or files."	061 - Network Security, slide 26	061 - Network Security::s26::1	0.77	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 28; 011 - Introduction to Computer Security, slide 9; 051 -

© Hak Cipta Universiti Teknologi MARA

Software Security, slide 6; 061 - Network Security, slide 26

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A small company runs a shared Linux server for its staff. The administrator notices that several users still rely on weak passwords and that failed login attempts are never acted upon. She decides to strengthen the password security controls on the server.

Question:

Explain five password security controls the administrator can apply to strengthen authentication on the shared Linux server.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Apply access control to the password files so that they are protected from unauthorised reading.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.44 LOW	supported
2	De-activate user accounts automatically after several failed login attempts.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.56	supported (ste gate)
3	Show the time of the user's last login so that suspicious activity can be noticed.	"Displaying the time of a last login"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.33 LOW	partly supporte
4	Enforce password policies, for example for the root password.	"Password policies, e.g. for root password"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.60	supported (ste gate)
5	Store passwords in an encrypted form using a one-way hash function rather than in plain text.	"Password is stored in an encrypted form using a one-way hash function:"	022 - Identification and Authentication, slide 8	022 - Identification and Authentication::s08::1	0.64	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 12; 022 - Identification and Authentication, slide 8

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

The administrator in the scenario wants to reduce the number of passwords staff must remember and type on the shared Linux server. Explain five points about single sign-on and Kerberos that she should understand before adopting such a mechanism.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Single sign-on reduces the burden of remembering many passwords for users.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.25 LOW	supported
2	Single sign-on cuts down the time users spend typing passwords.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.25 LOW	supported
3	Kerberos is a single sign-on method that automates authentication across	"Single sign-on methods such as Kerberos provide means for automating authentication in large distributed environments."	022 - Identification and Authentication, slide 24	022 - Identification and Authentication::s24::1	0.90	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	large distributed environments.					
4	Kerberos is designed so that passwords are never transmitted in clear text, protecting against eavesdropping.	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.50	supported (ste gate)
5	Kerberos is transparent to the user, who is unaware of any authentication beyond the initial login.	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.70	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 24

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss software insecurity and buffer overflows in the context of the consultant's review. Your answer should address the root causes of software insecurity, how a stack buffer overflow occurs, and the mitigation techniques available.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Explain that software insecurity arises because an attacker can modify system resources that are critical for program execution, such as the instruction pointer or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.72	supported (ste gate)
2	Identify failed validation of user input as one of the key sources of software insecurity.	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30	051 - Software Security::s30::1	1.00	supported (ste gate)
3	Describe how a local buffer allocated on the stack can, without proper bound checking, overspill into the adjacent upper stack area.	"Without proper bound checking a buffer content can overspill into adjacent upper stack area."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.86	supported (ste gate)
4	Explain that by controlling the buffer content an attacker can overwrite the return address with an arbitrary value and thereby hijack the execution flow.	"By controlling buffer content, an attacker can overwrite the return address with an arbitrary value and hijack the execution flow."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.86	supported (ste gate)
5	Name the special techniques for strengthening software security, namely canaries, address space layout randomization and data execution prevention.	"Special techniques for strengthening software security exist, e.g. canaries, address space layout randomization and data execution prevention."	051 - Software Security, slide 30	051 - Software Security::s30::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

© Hak Cipta Universiti Teknologi MARA

Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 21; 051 - Software Security, slide 30

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State five Windows security mechanisms or features that the consultant would examine, and for each, note the security concern it raises.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Windows provides complex mechanisms for managing user accounts and objects as well as controlling access.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.91	supported (ste gate)
2	Discretionary access control enables detailed control over access to diverse entities within Windows and its applications.	"DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.55	supported (ste gate)
3	The very complexity of these mechanisms can cause serious security incidents through misconfiguration or implementation bugs.	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.50	supported (ste gate)
4	Active Directory, introduced with Windows 2000, acts as a directory service for organising system resources.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.80	supported (ste gate)
5	Security credentials for a subject are held in a token that maps principals to subjects and may carry extra security attributes.	"Security credentials for a subject are stored in a token."	041 - Windows Security, slide 11	041 - Windows Security::s11::1	0.36 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 21; 041 - Windows Security, slide 6

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA